

CÓMO CREAR UN PROGRAMA DE CONTINUIDAD DEL NEGOCIO Y RECUPERACIÓN ANTE DESASTRES

Guía práctica de análisis de impacto, estrategias de recuperación, gestión de crisis, resiliencia cibernética, pruebas y mejora continua

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

CC BY-NC-SA 4.0

Propósito y aviso de uso responsable

Este manual ayuda a las organizaciones a prepararse para interrupciones mientras protegen a las personas, los servicios críticos, los datos, las instalaciones, la tecnología, los proveedores y la confianza pública. Las decisiones de continuidad y recuperación deben basarse en impactos documentados, seguridad humana, obligaciones legales y capacidades reales.

Tabla de contenido

- 1. Continuidad, recuperación y resiliencia cibernética
- 2. Gobierno, política y responsabilidades
- 3. Alcance e inventario de servicios críticos
- 4. Análisis de impacto al negocio
- 5. Evaluación de riesgos y escenarios
- 6. Objetivos MTPD, RTO, RPO y WRT
- 7. Estrategias de continuidad y recuperación
- 8. Recuperación tecnológica
- 9. Copias de seguridad y restauración
- 10. Resiliencia de nube y SaaS
- 11. Recuperación de incidentes y ransomware
- 12. Gestión de crisis y comunicaciones
- 13. Personal, instalaciones y trabajo alternativo
- 14. Continuidad de proveedores
- 15. Desarrollo y documentación de planes
- 16. Pruebas, ejercicios y validación
- 17. Métricas, evidencia y revisión directiva
- 18. Mantenimiento y mejora continua
- 19. Hoja de ruta de 30, 60 y 90 días
- 20. Listas, plantillas, glosario y referencias

1. Continuidad, recuperación y resiliencia cibernética

- La continuidad mantiene productos y servicios prioritarios en un nivel aceptable durante una interrupción.
- La recuperación ante desastres restaura tecnología, datos, aplicaciones, infraestructura y servicios de apoyo.
- La gestión de crisis coordina decisiones, seguridad, comunicaciones, obligaciones legales y partes interesadas.
- La resiliencia cibernética ayuda a anticipar, resistir, recuperar y adaptarse a condiciones adversas.
- Estas disciplinas deben funcionar de manera integrada.

2. Gobierno, política y responsabilidades

- Asigne patrocinador ejecutivo y propietario del programa.
- Defina funciones para negocio, TI, ciberseguridad, instalaciones, recursos humanos, asuntos legales, privacidad, comunicaciones, compras, finanzas y proveedores.
- Apruebe una política con alcance, objetivos, requisitos, frecuencia de pruebas, informes, excepciones y revisión.
- Defina quién puede declarar crisis, activar planes, aprobar gastos, comunicar y volver a la normalidad.
- Registre aceptación de riesgo y brechas.

3. Alcance e inventario de servicios críticos

- Inventarie productos, servicios, procesos, aplicaciones, datos, instalaciones, personas, equipos, servicios públicos, proveedores y compromisos regulatorios.
- Mapee dependencias y puntos únicos de falla.
- Identifique niveles mínimos de servicio y degradación aceptable.
- Separe servicios verdaderamente críticos de actividades que pueden esperar.
- Asigne propietario y fecha de revisión.

4. Análisis de impacto al negocio

- Entreviste propietarios y valide con finanzas, tecnología, operaciones y dirección.
- Evalúe impactos en el tiempo: seguridad, clientes, legales, financieros, operacionales, reputación, ambiente y sociedad.
- Documente períodos críticos, fechas límite, alternativas manuales, dependencias, registros, personal y secuencia.
- Use datos cuantitativos cuando existan y explique incertidumbre.
- Actualice después de cambios importantes.

5. Evaluación de riesgos y escenarios

- Evalúe desastres naturales, fallas de servicios, pérdida de instalaciones, ausencia de personal, ciberataques, ransomware, corrupción de datos, proveedores, nube, telecomunicaciones, disturbios y salud pública.
- Considere fallas simultáneas y en cascada.
- Evalúe probabilidad, impacto, aviso, duración, concentración y complejidad.
- Use escenarios para probar estrategias.
- No suponga que el seguro reemplaza la capacidad de recuperación.

6. Objetivos MTPD, RTO, RPO y WRT

- El período máximo tolerable de interrupción es el límite antes de consecuencias inaceptables.
- El RTO es el tiempo objetivo para restaurar.
- El RPO es la pérdida máxima aceptable de datos medida en tiempo.
- El WRT cubre validación, conciliación, atraso y preparación después de restaurar tecnología.
- Los objetivos deben ser aprobados y respaldados por capacidades probadas.

7. Estrategias de continuidad y recuperación

- Seleccione estrategias para personas, instalaciones, tecnología, datos, proveedores, comunicaciones, finanzas y liderazgo.
- Las opciones incluyen trabajo remoto, sitios alternos, redundancia, procedimientos manuales, inventarios, capacitación cruzada, proveedores alternos y diversidad geográfica.
- Compare costo, velocidad, capacidad, seguridad, complejidad y riesgo residual.
- Documente prerrequisitos y condiciones de activación.
- Una estrategia no es creíble hasta que esté financiada, implementada y probada.

8. Recuperación tecnológica

- Mapee aplicaciones con infraestructura, identidad, redes, bases, certificados, DNS, almacenamiento, integraciones y proveedores.
- Documente orden de recuperación y dependencias.
- Mantenga diagramas, procedimientos, configuraciones, licencias, credenciales, automatización y contactos.
- Separe administración de producción y recuperación.
- Pruebe failover, reconstrucción, restauración y retorno.
- Defina criterios de recuperación completa.

9. Copias de seguridad y restauración

- Clasifique datos y alinee frecuencia con RPO.
- Use varias copias protegidas y copias sin conexión o inmutables.

- Separe credenciales e infraestructura de backup de las rutas de compromiso.
- Cifre, monitoree fallas y pruebe restauración.
- Proteja datos y configuraciones SaaS.
- Documente retención y eliminación segura.

10. Resiliencia de nube y SaaS

- Comprenda responsabilidad compartida de disponibilidad, copias, identidad, configuración y recuperación.
- Diseñe para fallas regionales, zonales, de cuenta y de identidad cuando corresponda.
- Mantenga infraestructura como código y copias independientes.
- Revise niveles de servicio, exclusiones, comunicación, exportación y salida.
- Pruebe recuperación sin consola normal, proveedor de identidad o conexión.
- Gestione concentración de proveedores.

11. Recuperación de incidentes y ransomware

- Integre continuidad, recuperación, respuesta, asuntos legales, privacidad, comunicaciones y dirección.
- Suponga que identidad, virtualización, copias, monitoreo y comunicaciones pueden estar afectados.
- Conserve evidencia mientras prioriza seguridad y restauración.
- Restaure desde fuentes verificadas y valide antes de reconectar.
- Prepare entornos aislados y credenciales limpias.
- Ejercite decisiones sobre interrupción prolongada, extorsión, robo de datos y divulgación.

12. Gestión de crisis y comunicaciones

- Mantenga equipo de crisis, suplentes, contactos, registros de decisiones y escalamiento.
- Prepare plantillas internas, para clientes, proveedores, reguladores, medios y público.
- Use hechos verificados y explique lo conocido, desconocido y las acciones.
- Ofrezca comunicaciones accesibles y multilingües.
- Mantenga métodos fuera de banda.
- Coordine con asuntos legales, privacidad, seguridad, operaciones y dirección.

13. Personal, instalaciones y trabajo alternativo

- Proteja la vida y la seguridad antes de restaurar servicios.
- Planifique pérdida de oficinas, plantas, centros de datos, transporte, energía, agua y telecomunicaciones.
- Identifique personal mínimo, sucesión, capacitación cruzada, viajes, trabajo remoto y adaptaciones.

- Ofrezca procedimientos accesibles.
- Proteja credenciales, equipos y suministros.
- Considere fatiga, salud mental, familia y turnos sostenibles.

14. Continuidad de proveedores

- Identifique proveedores críticos, subcontratistas, logística, nube, telecomunicaciones, servicios públicos y soporte.
- Revise planes, evidencia de pruebas, concentración y estabilidad.
- Incluya notificación, recuperación, cooperación, devolución de datos, salida y pruebas en contratos.
- Mantenga alternativas cuando sea práctico.
- Ejercite interrupciones internas y externas simultáneas.

15. Desarrollo y documentación de planes

- Cree planes concisos de crisis, continuidad, recuperación TI, recuperación cibernética, comunicaciones, instalaciones y proveedores.
- Incluya propósito, alcance, supuestos, activación, roles, contactos, acciones, dependencias, alternativas, pasos, validación y retorno.
- Use listas y árboles de decisión.
- Guarde copias protegidas en línea y fuera de línea.
- Controle versiones y retire planes obsoletos.

16. Pruebas, ejercicios y validación

- Use revisiones, pruebas de llamadas, mesas de trabajo, restauración técnica, simulaciones, failover y ejercicios operacionales.
- Pruebe personas, decisiones, tecnología, proveedores, comunicaciones, instalaciones y evidencia.
- Defina objetivos, alcance, límites de seguridad, criterios, observadores y reversión.
- Registre brechas, responsables, fechas y nueva prueba.
- No afirme capacidad solo porque existe un plan.

17. Métricas, evidencia y revisión directiva

- Mida cobertura BIA, objetivos aprobados, vigencia de planes, ejercicios, restauración, brechas, fallas de copias, proveedores y capacitación.
- Compare desempeño demostrado con RTO y RPO.
- Informe supuestos y concentración.
- Conserve políticas, BIA, planes, aprobaciones, ejercicios, restauración, lecciones, acciones y decisiones.

- Use revisión directiva para aprobar prioridades, recursos y riesgo.

18. Mantenimiento y mejora continua

- Revise después de ejercicios, incidentes, reorganizaciones, adquisiciones, migraciones, cambios de proveedores y regulación.
- Valide contactos y procedimientos.
- Cierre acciones con evidencia.
- Use lecciones sin culpar a personas.
- Retire sistemas, dependencias, credenciales y documentos obsoletos.
- Considere interrupciones relacionadas con el clima cuando sean relevantes.

19. Hoja de ruta de 30, 60 y 90 días

- Días 1 a 30: establecer gobierno, identificar servicios críticos, realizar BIA rápidos, validar contactos, revisar copias e identificar puntos únicos.
- Días 31 a 60: aprobar objetivos, documentar estrategias, actualizar planes, establecer comunicaciones fuera de banda y revisar proveedores.
- Días 61 a 90: realizar ejercicios, cerrar brechas, establecer métricas, automatizar recordatorios y completar revisión directiva.

20. Listas, plantillas, glosario y referencias

Lista de preparación

- ☐ Patrocinador y propietario asignados
- ☐ Servicios críticos y dependencias inventariados
- ☐ Análisis de impacto aprobado
- ☐ MTPD, RTO, RPO y WRT definidos
- ☐ Estrategias financiadas e implementadas
- ☐ Autoridad de crisis y comunicaciones documentadas
- ☐ Secuencia de recuperación validada
- ☐ Copias fuera de línea o inmutables protegidas
- ☐ Dependencias de nube y proveedores evaluadas
- ☐ Entorno de recuperación de ransomware preparado
- ☐ Procedimientos accesibles y sitios alternos documentados

- ☐ Planes almacenados en línea y fuera de línea
- ☐ Ejercicios de mesa y restauración completados
- ☐ Acciones correctivas cerradas
- ☐ Revisión directiva y aceptación de riesgo registradas

Campos de análisis de impacto

Campo	Ejemplo
Servicio	Procesamiento de pagos
Propietario	Operaciones financieras
Nivel mínimo	Solo pagos prioritarios
MTPD	24 horas
RTO	4 horas
RPO	15 minutos
WRT	2 horas
Período crítico	Cierre de mes
Dependencias	Identidad, red, gateway, base de datos y banco
Alternativa manual	Flujo limitado de aprobación de emergencia
Impacto legal	Informes contractuales y regulatorios
Prioridad	Nivel 1

Glosario

Término	Definición
BCMS	Sistema de gestión de continuidad del negocio.
BIA	Análisis de impacto al negocio.
MTPD	Período máximo tolerable de interrupción.
RTO	Tiempo objetivo de restauración.
RPO	Pérdida máxima aceptable de datos medida en tiempo.
WRT	Tiempo para validar, conciliar y reanudar trabajo después de restaurar.
Failover	Transferencia a una capacidad alterna.
Failback	Retorno controlado a la capacidad principal.
Gestión de crisis	Coordinación de liderazgo durante una interrupción.
Resiliencia cibernética	Capacidad de anticipar, resistir, recuperar y adaptarse.

Referencias oficiales

- NIST SP 800-34 Rev. 1 - Contingency Planning Guide for Federal Information Systems:
<https://csrc.nist.gov/pubs/sp/800/34/r1/upd1/final>

- NIST SP 800-160 Vol. 2 Rev. 1 - Developing Cyber-Resilient Systems:
<https://csrc.nist.gov/pubs/sp/800/160/v2/r1/final>
- NIST Cybersecurity Framework 2.0: <https://www.nist.gov/cyberframework>
- ISO 22301:2019 - Business Continuity Management Systems:
<https://www.iso.org/standard/75106.html>
- ISO 22301:2019/Amd 1:2024 - Climate Action Changes: <https://www.iso.org/standard/88412.html>

Licencia

Copyright © 2026 Alberto (Al) Leiva. Distribuido bajo la licencia CC BY-NC-SA 4.0.